

Endpoints implementados y conectados al backend

Portal de conciliación — Cóctel del Mar

Rama	feature/login-coctel-del-mar-integration
Backend	coctel_mid (Spring Boot) — Auth Service detrás del API Gateway
Versión	1.0 — 06-Oct-2026
Alcance	Llamadas HTTP reales que hace hoy el frontend (<code>AuthService</code>). Excluye mocks en memoria.
Responsable portal	Irving Canul

1. Resumen

12

endpoints conectados al backend real

5

de autenticación (`/auth/*`)

7

de administración de usuarios (`/users/*`)

20

de `api-endpoints.csv` aún sin conectar (sección 4)

Cómo se conecta. Todas las llamadas usan rutas relativas (`environment.apiUrl = ''`) que en desarrollo atraviesa `proxy.conf.json` hacia el gateway (`http://localhost:8082` ; rutas `/auth` y `/users`).

- **Bearer automático:** `authTokenInterceptor` agrega `Authorization: Bearer <accessToken>` a toda petición salvo `/auth/login` , `/auth/refresh` y `/auth/logout` (públicos). Un 401 en cualquier otra llamada invalida la sesión y redirige a `/login` .
- **Errores de negocio:** el backend responde { "error": string, "code": string } ; `httpErrorAlertInterceptor` muestra una alerta por `code` (catálogo en `auth-errors.ts`), salvo los que ya tienen UI propia (`INVALID_CREDENTIALS` , `ACCOUNT_LOCKED` , `SESSION_IDLE_TIMEOUT`).
- **Autorización en el servidor:** `/users/**` exige rol `ADMIN` o `ALTAS` (`SecurityConfig.java`); un 403 sin `code` es ese rechazo.

2. Tabla de endpoints

#	Método	Endpoint	Qué hace	Acceso
1	POST	/auth/login	Inicia sesión; devuelve tokens y datos del usuario	Público
2	POST	/auth/refresh	Rota access/refresh token (un solo uso)	Público
3	POST	/auth/logout	Invalida el refresh token	Público
4	GET	/auth/me	Valida la sesión y refresca roles/permisos	Bearer
5	POST	/auth/change-password	Cambia la contraseña (obligatorio en el primer acceso)	Bearer
6	GET	/users	Lista paginada/filtrada de usuarios	ADMIN · ALTAS
7	GET	/users/{id}	Detalle completo de un usuario	ADMIN · ALTAS
8	POST	/users	Alta de usuario (devuelve contraseña temporal)	ADMIN · ALTAS

9	PATCH	/users/{id}	Edita información personal y organización	ADMIN · ALTAS
10	PATCH	/users/{id}/status	Cambia el estado (activo / inactivo / bloqueado)	ADMIN · ALTAS
11	POST	/users/{id}/verify-email	Marca el correo como verificado (manual)	ADMIN · ALTAS
12	PATCH	/users/{id}/unlock	Desbloquea una cuenta bloqueada por intentos fallidos	ADMIN · ALTAS

{id} es el id numérico del `app_user` real (`AppUser.backendUserId` en el front), no el id `uXXXX` del mock.

3. Detalle por endpoint

3.1 Autenticación (/auth/*)

POST /auth/login		Público
Request	{ username, password }	
Respuesta 200	{ accessToken, refreshToken, expiresIn (s), user: UserSummaryDto } — user incluye roles , permissions , subsidiarias , ubicaciones , mustChangePassword	
Errores	401 INVALID_CREDENTIALS · 423 ACCOUNT_LOCKED (5 intentos fallidos)	
Front	AuthService.login() → Login.onSubmit() ; después completeLogin() guarda la sesión en sessionStorage	

POST /auth/refresh		Público
Request	{ refreshToken }	
Respuesta 200	{ accessToken, refreshToken, expiresIn } — el refresh anterior queda invalidado (rotación)	
Errores	401 INVALID_REFRESH_TOKEN · REFRESH_TOKEN_REUSED · REFRESH_TOKEN_EXPIRED · SESSION_IDLE_TIMEOUT (30 min sin actividad) · USER_LOCKED_OR_INACTIVE	
Front	AuthService.refreshAccessToken() (privado), disparado por un timer 30 s antes de que expire el access token. SESSION_IDLE_TIMEOUT cierra sesión y muestra el aviso de inactividad.	

POST /auth/logout		Público
Request	{ refreshToken }	
Respuesta 200	{ success: true }	
Front	AuthService.logout() (menú lateral y header). Best-effort: la sesión local se cierra aunque la llamada falle.	

GET /auth/me		Bearer
Respuesta 200	UserSummaryDto (id, email, displayName, phone, status, roles, permissions, subsidiarias, ubicaciones, mustChangePassword, lastLoginAt, emailVerified)	
Front	AuthService.me() / validateResumedSession() : al recargar la página revalida la sesión restaurada y refresca roles/permisos/catálogos. Los permisos efectivos del portal salen de este arreglo.	

POST /auth/change-password		Bearer
Request	{ currentPassword, newPassword }	
Respuesta 200	{ success: true }	
Errores	401 INVALID_CREDENTIALS (contraseña actual incorrecta). Mientras mustChangePassword sea true, el resto de endpoints protegidos responde 403 PASSWORD_CHANGE_REQUIRED .	
Front	AuthService.changePassword() → pantalla /cambiar-password (authGuard la fuerza antes de cualquier otra ruta)	

3.2 Administración de usuarios (/users/*) — rol ADMIN o ALTAS

GET /users		Lista paginada
Query	page (0) · size (100) · search ? · role ? · status ? (ACTIVE INACTIVE LOCKED)	
Respuesta 200	{ content: UserSummaryDto[], page, size, totalElements, totalPages }	
Front	UserManagementService.syncFromBackend() , al entrar a /usuarios : reconcilia roles/permisos/estado/ último acceso/subsidiarias/ubicaciones de cada cuenta conocida y agrega las cuentas reales que el mock no tiene (pidiendo su detalle).	

GET /users/{id}		Detalle completo
Respuesta 200	UserDetailDto : firstName, lastName, displayName, createdAt, birthDate, ssn, gender, address{city,state,postalCode,street1,street2,interiorNumber,exteriorNumber}, department, area, jobTitle, manager{id,displayName}, employeeCode, hireDate, contractEndDate, temporaryPassword + los campos de UserSummaryDto	
Errores	404 USER_NOT_FOUND	
Front	UserDetail (carga y fusiona sobre el registro local; se vuelve a pedir tras cada mutación) y syncFromBackend() para cuentas nuevas. temporaryPassword solo llega mientras mustChangePassword sea true.	

POST /users		Alta de usuario
Request	{ firstName, lastName, email, phone, supervisorId, subsidiariaIds[], ubicacionIds[], roleIds[], status: "ACTIVE" "INACTIVE" } — roleIds solo se respeta con el permiso manage_roles	
Respuesta 201	{ id, email, displayName, roles, permissions, subsidiarias, ubicaciones, mustChangePassword, temporaryPassword } — la contraseña temporal solo se devuelve aquí	
Errores	409 EMAIL_ALREADY_REGISTERED · 400 INVALID_ROLE / INVALID_USER_STATUS · 403 ROLE_ASSIGNMENT_FORBIDDEN	
Front	UserManagementService.createUser() ← formulario /usuarios/nuevo (roles, subsidiarias y ubicaciones múltiples; supervisor select simple)	

PATCH /users/{id}		Edición parcial
Request	{ firstName, lastName, email, phone, birthDate, ssn, gender, address, department, area, jobTitle, managerId, employeeCode, hireDate, contractEndDate } — solo sobrescribe lo no nulo. No incluye estado, roles, subsidiarias ni ubicaciones.	
Respuesta 200	UserSummaryDto (no repite los campos enviados)	
Errores	404 USER_NOT_FOUND · 409 EMAIL_ALREADY_REGISTERED	
Front	UserManagementService.updateUserProfile() ← "Guardar cambios" de Información general	

PATCH /users/{id}/status		Cambio de estado
Request	{ status: "active" "inactive" "blocked" } (minúsculas; blocked = enum LOCKED)	
Respuesta 200	UserSummaryDto — aquí status vuelve en mayúsculas (ACTIVE INACTIVE LOCKED)	
Errores	400 INVALID_USER_STATUS · 404 USER_NOT_FOUND	
Front	UserManagementService.setStatus() ← chip de estado en la lista y en el detalle (con confirmación)	

POST /users/{id}/verify-email		Verificación manual
Request	Sin cuerpo	
Respuesta 200	{ id, emailVerified: true } — fuerza el flag sin validar token pendiente	
Front	UserManagementService.setEmailVerified() ← "Marcar como verificado" en Seguridad y acceso	

PATCH /users/{id}/unlock		Desbloqueo
Request	Sin cuerpo	
Respuesta 200	Cuenta desbloqueada (ACTIVE , contador de intentos en 0); el front no usa el cuerpo	
Errores	403 (sin rol ADMIN/ALTAS, sin code) · 404 USER_NOT_FOUND	
Front	UserDetail.onUnlockBackendClick() ← "Desbloquear cuenta" (campo "Cuenta real (backend)")	

4. Documentados en docs/api-endpoints.csv y aún sin conectar

El portal los resuelve hoy con datos en memoria (mock). Al conectarlos, moverlos a las secciones 2 y 3 y subir la versión de este documento.

Módulo	Método	Endpoint	Hoy en el front
Usuarios	PATCH	/users/{id}/roles	Cambio de roles/permisos solo local
Usuarios	POST	/users/{id}/close-sessions	Contador local
Usuarios	POST	/users/{id}/reset-password	Genera contraseña local (toast)
Usuarios	DELETE	/users/{id}	Opción retirada del front (el backend tampoco la expone)
Usuarios	GET	/users/{id}/audit-log · /audit-log	Bitácora en memoria (appendAudit)
Usuarios	GET	/roles · /permissions · /catalogs/organization	Catálogos hardcoded en el modelo
Ventas	GET	/sales · /sales/{id} · /sales/export	MOCK_SALES ; exportación CSV en el cliente
Ventas	POST	/sales/{store}/{date}/reprocess	Simulado con setTimeout
Conciliación	GET	/reconciliation · /reconciliation/kpis · /tender-media/status	Datos mock
Conciliación	GET	/reconciliation/{tenderMedia}/{date}/settlements	Datos mock
Conciliación	POST	/reconciliation/{tenderMedia}/{date}/unreconcile	Store en memoria
Conciliación	GET	/bank-accounts	Cuentas mock
Conciliación	POST	/bank-imports	Archivo parseado en el navegador, no se envía

Total: 20 endpoints del CSV sin conectar (los 9 restantes del CSV ya están en la sección 2, junto con /auth/refresh , /auth/change-password y /users/{id}/unlock , que no figuran en el CSV).

5. Historial de versiones

Versión	Fecha	Cambios
1.0	06-Oct-2026	Versión inicial: 12 endpoints conectados (5 de /auth , 7 de /users) en feature/login-coctel-del-mar-integration .